EWB COURSES

AI-POWERED CYBERSECURITY

Assessment 01: Security Foundations

Tasks A–D | Final Assessment Report

Student Name: Ramagouni Thanuja

Batch/Group: 2 October 2026

Submission Date: 1 November 2026

Prepared using the fictional scenarios and synthetic evidence supplied in the assessment.

Task A — Secure a Student Account

Introduction

Mira's habits put her email, learning portal, laptop, and academic project at risk. The CIA triad helps explain the possible impact: confidentiality means information is seen only by authorised people; integrity means information is not changed without permission; availability means information is accessible when needed.

A1. Five risks and CIA impact

1. Reusing a short password: The email and learning portal are at risk. A short password may be guessed, and reuse means exposure of one account can put the other at risk. Confidentiality may be lost, assignments or account settings may be changed (integrity), and Mira may be locked out (availability).

2. Approving unexpected sign-in prompts: An unexpected approval may authorise a login Mira did not initiate. Private information may be viewed, account settings or assignments may be changed, and access may be disrupted. Repeated prompts should be denied and reported.

3. Postponing updates: Outdated operating systems and applications may contain known vulnerabilities. Exploitation could expose data, modify or corrupt files, or disrupt the laptop and its services.

4. Keeping only one project copy: The project may be lost through laptop damage, theft, failure, accidental deletion, or corruption. This mainly threatens availability and integrity; private files may also be exposed if the device is stolen and unprotected.

5. Sharing a signed-in laptop: A friend may access existing sessions without entering Mira's password. This can expose email and academic information, allow changes or deletion of files, and disrupt access.

A2. Controls, limitations, and first priorities

Mira should use a unique, strong password for each account and a reputable password manager. This limits the effect of one exposed password, but cannot prevent every phishing or session-theft attack. She should deny unexpected MFA prompts, report repeated requests, and review active sessions; this reduces accidental approval but does not rule out an already compromised session. She should enable and promptly install security updates; updates fix known weaknesses but cannot remove every vulnerability. She should keep a regular backup on a trusted cloud service or separate external drive and test restoration; a backup can be outdated or affected by the same incident. She should lock the laptop, sign out of sensitive services, and give her friend a separate user account; this helps protect privacy but fails if the device is left unlocked.

Priority 1: Deny unexpected sign-in prompts and report repeated requests. If one was already approved, secure the account and contact official IT support.

Priority 2: Replace reused passwords with unique ones, prioritising email, and review/revoke suspicious sessions. A password change alone may not end every active session.

Priority 3: Lock the laptop and use a separate account for the friend. Then install pending updates and create a reliable backup.

A3. Authentication versus authorisation

Authentication verifies who a user is, for example when Mira enters her password and completes a legitimate MFA check. Authorisation determines what an authenticated user is allowed to do. Mira may be allowed to view course notes and submit her own assignment, but not change another student's grades or use administrator functions. In short, authentication asks "Who are you?" while authorisation asks "What are you allowed to access or do?" Both are needed to protect accounts and academic records.

Task B — Phishing Message Analysis

Introduction

The fictional email claims that a scholarship expires in 20 minutes and asks the student to enter a college password and OTP, provide an identity-card photo, and avoid contacting the college office. These are serious warning signs that should be checked independently.

B1. Five warning signs

1. Urgent, threatening language: “FINAL WARNING” is designed to create fear and rush the student into acting without checking.

2. Very short deadline: A 20-minute expiry may pressure the student to skip verification. The deadline itself does not prove that the offer is genuine.

3. Sender and Reply-To mismatch: The sender is awards@campus-awards.example while Reply-To is help@personal-awards.example. The different domains are suspicious, though the mismatch alone does not prove fraud.

4. Password and OTP request: An unsolicited request for a college password and one-time password could enable account access. Passwords and OTPs should never be sent in response to such an email.

5. ID photo request and discouraging verification: An identity-card image could be misused for impersonation. Telling the student not to contact the college office discourages independent checks and is suspicious.

B2. Safe verification; HTTPS and display names

Do not click the email link, download attachments, reply, or share information. Check the full sender and Reply-To addresses, but remember that displayed sender details alone do not prove identity. Open the college’s official website using a known address or contact the scholarship office using details obtained independently; do not use phone numbers or links supplied in the message. Ask whether the award, process, required documents, and deadline are genuine. Report the email to the college IT/security team and preserve the original message and headers if requested. HTTPS encrypts traffic between a browser and a website, but phishing sites can also use HTTPS. A familiar display name can be copied, so neither HTTPS nor a display name proves legitimacy.

B3. If the password and OTP were already entered

Immediately open the official college portal independently and change the password. If the password was reused, change it on every affected service to a unique password. Contact authorised IT/security support through an official channel, explain what was entered and when, and request review of sign-in activity. Revoke active sessions, inspect recovery details and MFA methods, and remove unfamiliar changes with IT guidance. Preserve the suspicious message and report it. If an identity-card photo was sent, inform the appropriate college office and ask what precautions are needed. Never send passwords or OTPs to support staff.

B4. One unknown and evidence needed

The email alone cannot prove who sent it or whether the sender’s account is compromised. Additional evidence could include full email headers and mail-server records, plus independent confirmation from the official scholarship office. If credentials were entered, authorised IT staff should also review sign-in and session logs. These checks may help clarify the source and impact, but conclusions should remain limited to what the evidence supports.

Task C — Triage a Sign-in Alert

C1. Four-point timeline: observed facts and interpretation

1. 09:00–09:01 IST: Observed: password sign-in succeeds from 192.0.2.10 at 09:00; MFA is approved from the same address at 09:01. Interpretation: consistent with the student's earlier access pattern, but logs alone do not prove who operated the device.

2. 10:14–10:15 IST: Observed: two password attempts fail from 198.51.100.23. Interpretation: could be mistyped credentials, guessing, or another unsuccessful attempt; suspicious in context but not conclusive by itself.

3. 10:16–10:18 IST: Observed: password succeeds at 10:16, MFA is denied at 10:17, and MFA is approved at 10:18. The student says they did not sign in after 09:05 and approved a prompt thinking it would stop repeated requests. Interpretation: possible MFA-prompt manipulation or confusion.

4. 10:20 IST: Observed: a session is created from 198.51.100.23. Interpretation: the sequence raises concern about possible unauthorised access and needs investigation.

C2. Likely explanation, alternative, and two checks

Likely explanation: another person may have obtained or guessed the password; after the password succeeded, the student's approval of an unexpected MFA prompt may have allowed a session to be created. This is consistent with possible account compromise, but it does not identify the person behind the IP address or prove how the password was obtained.

Alternative explanation: the student or another authorised user may have signed in from a different network, mobile data, VPN, or device, or a logging issue may have created confusing records. This fits the student's statement less well, but should be checked.

Checks: (1) Review detailed authentication/session records, device and browser information, MFA method, timestamps, session identifiers, risk signals, and security-setting changes. (2) Confirm the timeline with the student through a trusted channel and review activity after 10:20, including accessed resources, downloads, forwarding rules, and account changes. Preserve logs before they expire.

C3. Three prioritised actions for authorised IT

1. Contain and secure: revoke the suspicious and other active sessions/tokens, reset the password through a trusted process, and review MFA methods, recovery options, and security settings.

2. Preserve and investigate: export relevant authentication, MFA, session, and audit logs with timestamps; record the student's account; correlate with device and resource activity. Investigate only systems the team is authorised to administer.

3. Assess impact and monitor: check whether information was viewed, downloaded, changed, or shared; remove unauthorised changes; restore access safely; notify the appropriate security contact; and monitor for repeated attempts or new suspicious sessions.

C4. Incident summary (82 words)

On 18 October 2026, the synthetic logs show two failed password attempts from 198.51.100.23, followed by a successful password attempt, an MFA denial, an MFA approval, and session creation at 10:20 IST. The student denies signing in after 09:05 but confirms approving an MFA prompt. This suggests possible account compromise, although the source IP does not identify a person or prove an attack. The priority is to revoke suspicious sessions, secure the account, preserve authentication evidence, and investigate further activity.

Task D — Review an AI Security Answer

D1. Five unsafe or unsupported claims/actions

1. "The email is safe because it uses HTTPS.": Incorrect. HTTPS encrypts traffic but does not prove a website or email is genuine. Phishing sites can also use HTTPS. Urgency, a mismatched Reply-To, requests for a password and OTP, and an ID-photo request are warning signs.

2. "The logs prove the person at 198.51.100.23 stole the password.": Unsupported. The logs show failed attempts, a successful password event, MFA denial, MFA approval, and session creation. They do not identify the person or establish how the password was obtained.

3. "MFA prevents every account compromise.": Incorrect. MFA reduces risk but is not foolproof. A user may approve a fraudulent prompt, or a session/authentication method may be compromised.

4. "Delete the suspicious logs.": Unsafe. Logs should be preserved securely because they may be important evidence. Authorised IT staff should record timestamps, restrict access, and analyse events.

5. "Send the student's password to support.": Unsafe. Passwords and OTPs must never be shared. The student should change the password through the official portal, revoke sessions, review account activity, and contact authorised IT support.

D2. Improved AI prompt

Act as a cybersecurity analysis assistant. Analyse only the fictional scholarship email and synthetic sign-in logs supplied in this assessment. Identify suspicious signs and unusual events. Separate observed facts from interpretations, assumptions, and unknowns. Do not claim that an IP address identifies a person or proves password theft. Explain the limitations of HTTPS and MFA. Recommend safe, prioritised account-protection and investigation steps. Preserve logs; never recommend deleting evidence or sharing passwords, OTPs, or identity documents. Support key recommendations with trustworthy references such as CISA and NIST. State evidence limitations, suggest additional checks, and do not invent facts. Use the headings Observed Evidence, Analysis and Uncertainty, Recommended Security Actions, and References.

D3. Corrected security advice (100–150 words)

The scholarship email should be treated as suspicious because it creates urgency, requests a college password and OTP, and contains a different Reply-To address. Students should not click the link or share personal information. They should verify the scholarship through the official college portal or an independently obtained contact.

The sign-in logs show two failed password attempts, a successful password event, an MFA denial, an MFA approval, and session creation from an unfamiliar IP address. These events raise concerns about possible unauthorised access, but they do not prove who used the IP address or how the password was obtained.

The student should contact authorised IT support, change the password through the official portal, revoke active sessions, and review account activity. The IT team should preserve logs and investigate the incident. MFA improves security but cannot prevent every compromise. Passwords and OTPs must never be shared with support staff.

D4. AI-use declaration and evidence/reference notes

AI-use declaration: I used ChatGPT as an AI assistance tool to understand cybersecurity concepts, identify unsafe and unsupported claims in the fictional AI-generated answer, and organise my responses. I reviewed the recommendations against the supplied assessment evidence and the references below. I understand that AI-generated information may contain errors and that important claims must be verified. I will review and adapt the final report in my own words before submission.

Reference 1: Cybersecurity and Infrastructure Security Agency (CISA), Secure Our World — https://www.cisa.gov/secure-our-world. This guidance supports recognising phishing, using strong passwords, and protecting accounts with MFA.

Reference 2: National Institute of Standards and Technology (NIST), Generative AI Profile (AI 600-1) — https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf. This publication discusses generative-AI risks, including false or unsupported outputs.

Evidence note: The supplied scenario is fictional and uses synthetic sign-in logs. The email and logs support caution and further investigation, but do not establish the identity of the person behind an IP address or conclusively prove how a password was obtained.